
CTF WriteUp — traffic_hunt

题目概述

题目提供了一份 **恶意网络流量抓包 (PCAP)**，要求分析攻击者行为，并从流量中恢复最终的 Flag。

Flag 格式为：

```
1 | dart{}
```

本题的本质是一次 **网络流量取证 + Web 攻击链分析**。

通过对流量进行逐步分析，可以还原攻击者从 **前期信息收集** → **漏洞利用** → **植入后门** → **远程控制** → **数据回传** 的完整攻击过程。

一、初步流量分析

首先使用 **Wireshark** 打开题目提供的流量文件，对 HTTP 请求进行筛选：

```
1 | http
```

可以观察到攻击者主机：

```
1 | 10.1.243.155
```

持续访问目标服务器：

```
1 | 10.1.33.69:8080
```

并请求了多个敏感路径，例如：

```
1 | /login.php
2 | /login.jsp
3 | /server.xml
4 | /api/docs
5 | /api/swagger/index.html
6 | /api/api-docs/swagger.json
```

行为分析

这些访问行为具有明显特征：

1. **目录扫描**
2. **Web 框架识别**
3. **API 文档探测**

尤其是以下路径：

```
1 /api/swagger/index.html
2 /api/api-docs/swagger.json
```

通常用于：

- Swagger API 文档
- REST API 接口枚举

说明攻击者正在寻找 **可利用接口**。

因此可以判断：

攻击者在这一阶段主要进行 **信息收集与漏洞探测**。

二、发现关键利用流量

在进一步分析流量时，可以发现一条非常关键的 **POST 请求**。

请求参数中包含：

```
1 p: Hwmc2TLDoihd1r0N
2 path: /favicondemo.ico
3 user=...
```

其中：

```
1 user=
```

后面是一段 **编码后的数据**。

对该数据进行解码后，可以发现典型的 **Java class 字节码特征字符串**：

```
1 yv66vgAA
```

Java Class 文件特征

```
1 yv66vgAA
```

是 **Java .class 文件的魔数**，说明该数据实际上是一段 **Java 字节码**。

进一步分析字符串，可以发现以下关键内容：

```
1 com/summersec/x/BehinderFilter
2 BehinderFilter.java
3 addFilter
4 doFilter
```

关键判断

这些特征明确指向：

```
1 | Behinder 内存马
```

并且类型为：

```
1 | Java Filter Memory Shell
```

攻击者通过漏洞将 **BehinderFilter** 注入到了服务器内存中。

三、后门路径伪装

从请求参数中可以看到：

```
1 | path: /favicondemo.ico
```

攻击者将后门访问路径伪装成：

```
1 | /favicondemo.ico
```

这样做的目的包括：

1. 隐藏恶意访问
2. 绕过日志检测
3. 伪装为普通资源文件

因此可以判断：

```
| /favicondemo.ico 实际上是 内存马控制入口。
```

四、后门通信行为分析

在内存马植入成功后，可以观察到攻击者开始频繁向：

```
1 | /favicondemo.ico
```

发送 POST 请求。

这一阶段的流量具有以下特征：

- 请求体长度较大
- 数据看起来像随机字符串
- 持续通信

例如：

```
1 POST /favicondemo.ico HTTP/1.1
2 Content-Length: xxx
```

请求体示例：

```
1 3SoX7GyGU1KBVYS3DYFbfqQ2CHqH2aPGwpfeyvv5MPY5Dm1Wt9VYRumoUvzdmoLw6FUm4AMqR5zoi
```

行为判断

这种通信模式符合 **Behinder WebShell 控制流量特征**：

- 数据经过加密
- 通过 HTTP POST 传输
- 控制端不断发送命令

因此：

攻击者已经进入 **WebShell / 内存马控制阶段**。

五、提取关键数据

在后续流量中，提取到一段关键字串：

```
1 3SoX7GyGU1KBVYS3DYFbfqQ2CHqH2aPGwpfeyvv5MPY5Dm1Wt9VYRumoUvzdmoLw6FUm4AMqR5zoi
```

观察该字符串特征：

- 只包含数字与大小写字母
- 不包含 `+` `/` `=`

因此可以推测其可能为：

```
1 Base58 编码
```

六、Base58 解码

首先对字符串进行 **Base58 解码**。

得到：

```
1 ZGFydHtkOTg1MGIyNy04NWNiLTQ3NzctODVlMC1kZjBiNzhmZGI3MjJ9
```

七、Base64 解码

可以发现解码后的字符串符合 **Base64 特征**。

再次进行 **Base64 解码**：

1 | dart{d9850b27-85cb-4777-85e0-df0b78fdb722}